

Relatório de Auditoria Técnica

Vibe | Segurança, lógica e integridade funcional

Data: 30 de setembro de 2026 | Classificação: revisão estática com validações automatizadas

Conclusão Executiva

Não foram identificados achados Críticos. Foram confirmados riscos Altos e Médios que devem ser tratados antes da publicação, com prioridade para XSS armazenado, segredos e dados sensíveis rastreados no Git, ausência de limitação de tentativas e exposição prematura de vídeos agendados.

A revisão cobriu código próprio PHP e JavaScript, rotas, migrations, configurações, Docker Compose e dependências. Não incluiu teste de intrusão em ambiente implantado, fuzzing, análise de logs de produção ou validação de controles externos como WAF e proxy.

Achados Altos

A-01 | XSS armazenado nas telas de histórico e moderação

Local: script.js, histórico de visualizações e lista de denúncias. Dados persistidos pelo usuário, incluindo nome e descrição do vídeo, são interpolados em innerHTML. Um vídeo malicioso pode executar JavaScript no navegador de quem consulta o histórico ou a moderação e tentar exfiltrar o token Bearer guardado em sessionStorage.

```
const title = document.createElement("strong");
title.textContent = video.author?.name || "Usuário";
item.replaceChildren(title, details);
```

Correção: construir os elementos com createElement e preencher conteúdo não confiável exclusivamente com.textContent. Aplicar também aos erros de API interpolados em HTML.

A-02 | Segredos em backend/.env rastreado pelo Git

Local: backend/.env. O arquivo está rastreado e contém valores preenchidos para APP_KEY, banco e Cloudinary; APP_DEBUG está habilitado. Valores reais expostos podem comprometer sessões, dados e serviços. Não reproduzidos neste relatório.

Correção: remover o arquivo do índice, usar secrets de implantação, rotacionar todas as credenciais potencialmente válidas e definir APP_DEBUG=false fora do desenvolvimento. A remoção do arquivo não elimina cópias do histórico Git.

```
git rm --cached backend/.env
```

A-03 | Dump com dados e tabelas de autenticação adicionado ao Git

Local: vibe-backup.sql. O dump contém registros não vazios de usuários, tokens de acesso e tokens de recuperação, além de outros dados da aplicação. Hashes e informações de conta devem ser tratados como sensíveis. Se o dump foi compartilhado, remover do histórico e invalidar credenciais/tokens potencialmente relacionados.

```
git rm --cached vibe-backup.sql
```

A-04 | Rotas de autenticação sem rate limit da aplicação

Local: backend/routes/api.php. route:list -vv confirmou que login não recebe middleware throttle. Cadastro e recuperação também não têm limite explícito. Isso facilita brute force, credential stuffing e abuso de criação de contas; eventual proteção externa não foi verificada.

```
Route::post("/login", [AuthController::class, "login"]->middleware("throttle:5,1"));
```

Correção: aplicar limites por IP e conta ao login, cadastro, recuperação e reenvio de e-mail; manter controles adicionais no proxy/WAF.

Achados Médios

M-01 | Vídeo agendado pode ser acessado antes da publicação

Local: VideoController::index filtra scheduled_at, mas Video::isVisibleTo não. A consulta direta por ID e outros fluxos que usam a checagem central podem revelar vídeo público antes do horário, contrariando o agendamento.

```
if ($this->scheduled_at?->isFuture() && (! $viewer || ! $viewer->is($this->user))) return false;
```

Correção: aplicar a regra de horário em isVisibleTo e nas consultas de perfil/listagem, permitindo preview somente ao proprietário.

M-02 | Fila offline não separa ações por usuário

Local: api-client.js. A fila em localStorage não guarda o ID do usuário; a reprodução usa o token da sessão atual. Após logout e login com outra conta, ações pendentes podem ser reenviadas sob a nova identidade. Falhas de rede ambíguas também podem duplicar POSTs não idempotentes.

Correção: associar cada ação à conta de origem, nunca reproduzir ações de outra conta, limpar/segregar fila no logout e usar chave de idempotência em operações de criação.

M-03 | Métricas públicas podem ser infladas

Local: POST /videos/{video}/view e /share em VideoController. Chamadas repetidas incrementam contadores sem autenticação ou deduplicação. Isso permite falsificar popularidade e afetar ordenação do feed.

Correção: aplicar rate limit e registrar eventos idempotentes por usuário/janela antes de incrementar os totais.

M-04 | MySQL do Compose usa senha fixa e porta exposta

Local: docker-compose.yml. As credenciais são estáticas e 3306:3306 publica a porta em todas as interfaces. Em rede compartilhada, o banco pode ficar acessível a terceiros.

```
ports: ["127.0.0.1:3306:3306"]
```

Correção: restringir o bind em desenvolvimento e fornecer credenciais por ambiente/secrets.

M-05 | Dependências com advisories conhecidos

composer audit --locked encontrou seis avisos em três pacotes: Laravel 13.23.0 (CVE-2026-102279, baixo), CommonMark 2.9.0 (quatro avisos altos de XSS/DoS, cuja explorabilidade depende das extensões e entradas processadas) e Flysystem 3.35.2 (CVE-2026-102601, baixo).

```
composer update laravel/framework league/commonmark league/flysystem --with-all-dependencies
```

Correção: atualizar para versões corrigidas compatíveis e executar composer audit novamente. Não há lockfile npm, portanto a auditoria frontend não é reproduzível.

M-06 | env() lido fora dos arquivos de configuração

Local: AuthController e ModerationController. VIBE_MODERATOR_EMAILS e VIBE_FRONTEND_URL são lidos em runtime. Após config:cache, valores definidos apenas no .env podem não estar disponíveis, afetando autorização de moderação e links de recuperação.

```
// config/services.php: definir moderator_emails e frontend_url via env()
$frontend = config("services.frontend_url");
```

Correção: concentrar variáveis em config/*.php e usar config() nos controladores.

M-07 | URL padrão da API usa HTTP e porta fixa

Local: script.js, DEFAULT_API_BASE_URL. Hosts não locais viram http://<host>:8000/api. Em página HTTPS, o navegador bloqueia essas chamadas por mixed content, salvo configuração externa de data-api-base-url.

```
const DEFAULT_API_BASE_URL = new URL("/api", window.location.origin).toString();
```

Correção: usar rota relativa quando frontend e API compartilham domínio; em domínios separados, configurar URL HTTPS por ambiente.

M-08 | Fechar gravação pode reabrir o editor

Local: script.js, fecharPublicacao e callback stop do MediaRecorder. Fechar o modal chama stop(), mas o callback ainda executa prepararPublicacao(file), reabrindo o editor depois do fechamento. O trecho selecionado está no caminho de reset de botões, não é a causa isolada.

```
if (discardRecordingOnStop) return;
```

Correção: marcar cancelamento antes de stop() no fechamento e ignorar o evento stop nesse caso; manter o fluxo normal quando a pessoa escolhe parar a gravação.

Achados Baixos e Informativos

L-01 | Fallback demo pode ocultar falha da API

index.html ativa data-demo-fallback=true. Em falha de conexão, o feed de demonstração substitui o estado da API sem abrir aviso visível. Desativar em produção ou exibir aviso persistente e opção de nova tentativa.

L-02 | Corrida ao escolher posição de playlist

A implementação atual atribui posição a novas inclusões e possui migration de backfill, corrigindo o problema original. Inclusões simultâneas ainda podem calcular o mesmo max(position)+1. Usar transação e garantir unicidade por playlist.

I-01 | E-mail e links ainda configurados para desenvolvimento

O ambiente local usa MAIL_MAILER=log e VIBE_FRONTEND_URL=http://localhost:5500.

Confirmação/recuperação não chegam a usuários reais e o link não funciona no celular. Configurar mailer e frontend HTTPS em produção.

I-02 | CORS cobre apenas parte das redes locais

O padrão atual aceita endereços 192.168.* na porta 5500, e CORS_ALLOWED_ORIGINS pode sobrescrevê-lo. Outras faixas privadas precisam ser configuradas por ambiente.

Correções parciais já presentes

A interface de moderação agora usa is_moderator fornecido pelo backend. Rotas privadas usam verified; o login ainda emite token a não verificados, mas isso não contorna o middleware nas rotas protegidas. A atribuição de posição e o backfill de playlists também já estão presentes.

Validação Executada

PHPUnit: 10 testes passaram, com 38 asserções. Lint PHP: todos os arquivos próprios verificados passaram. node --check: os nove scripts JavaScript passaram. composer audit: seis advisories encontrados. A suíte atual não cobre adequadamente os fluxos de segurança apontados.

Relatório gerado a partir da revisão do código e configurações disponíveis no workspace. Segredos não foram incluídos.